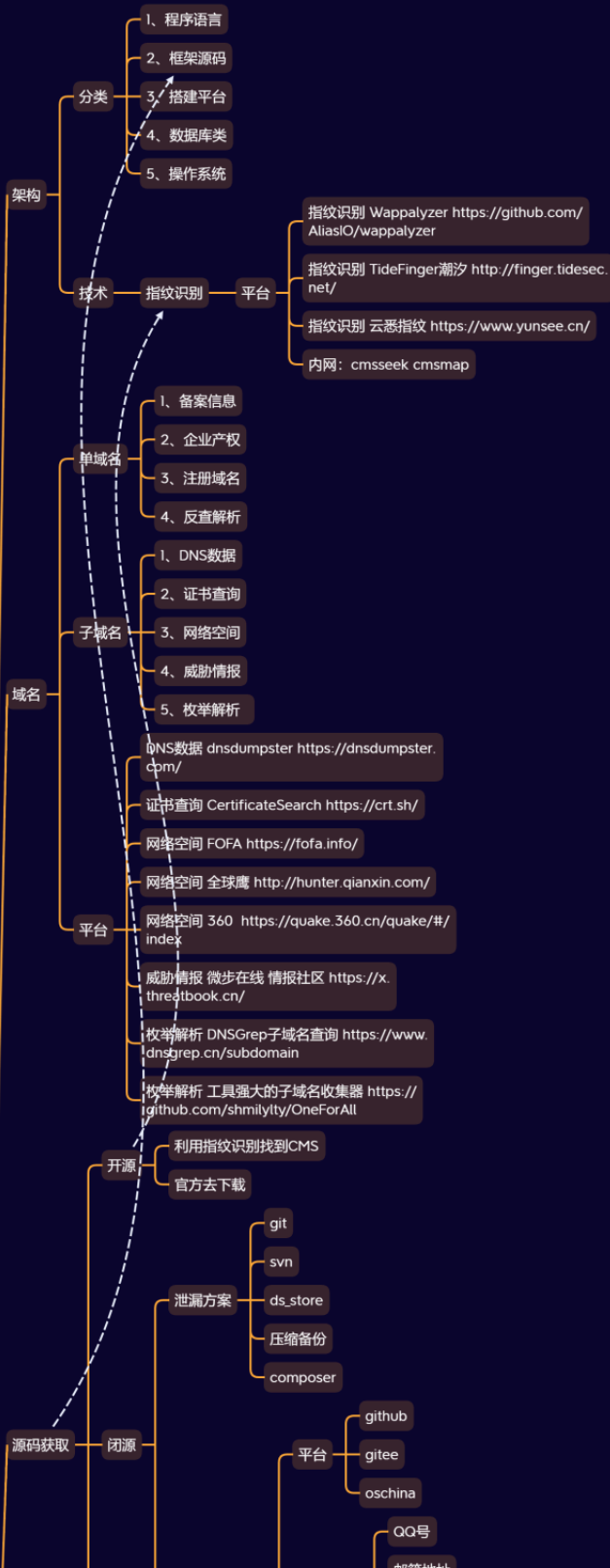


Day20 信息打点-红蓝队自动化项目&资产侦察&武器库部署&企查产权&网络空间

业务资产

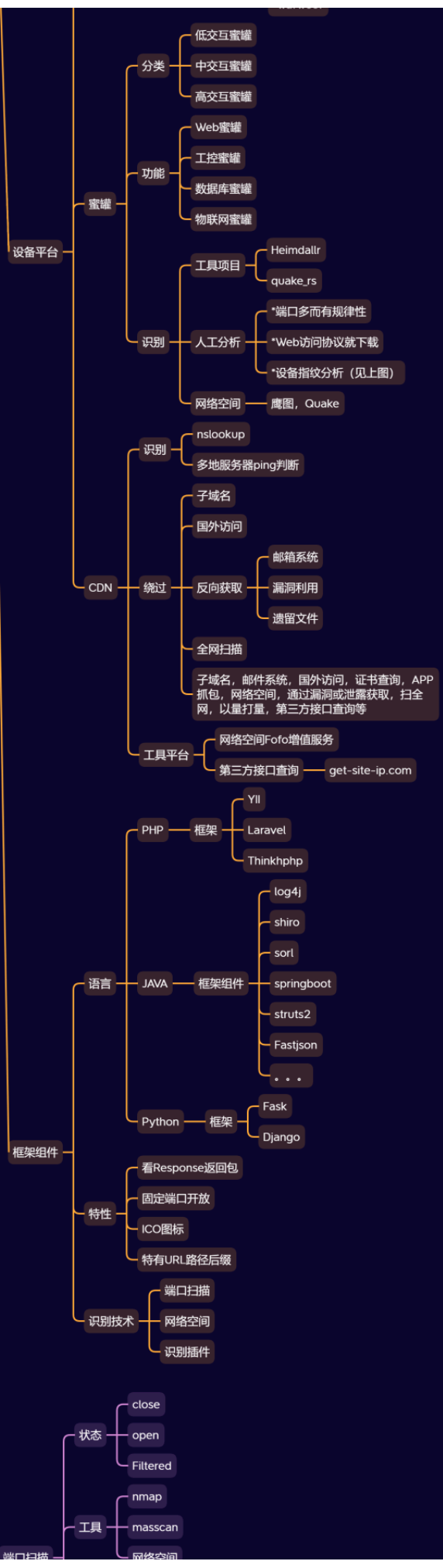
- 查询平台
 - 爱企查
 - 小蓝本
- 业务类型
 - 1、WEB应用
 - 2、APP应用
 - 3、PC端应用
 - 4、小程序应用
 - 5、微信公众号
 - 6、其他产品等

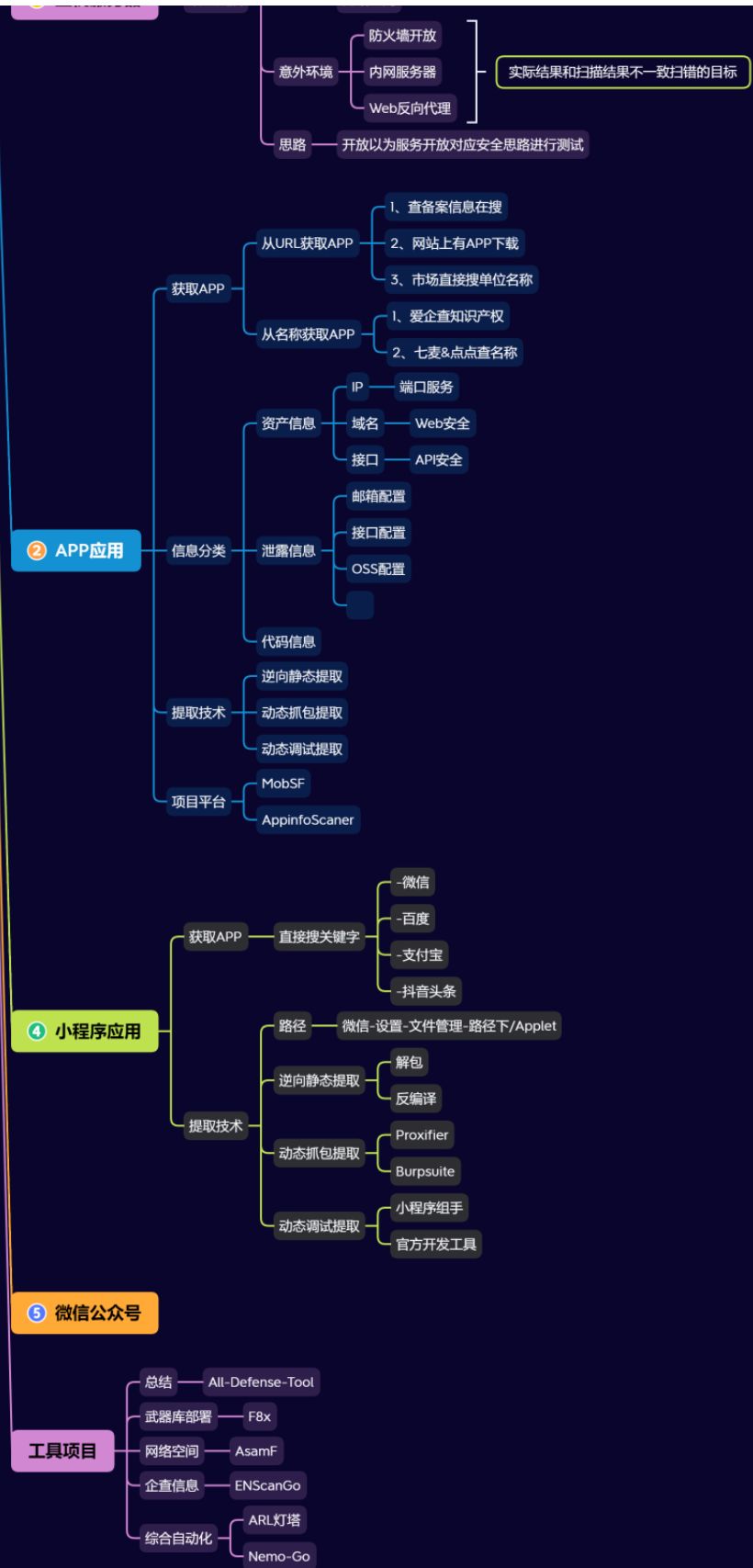


① Web应用

JS前端架构







1.知识点

- 1、业务资产-应用类型分类
 - 2、Web单域名获取-接口查询
 - 3、Web子域名获取-解析枚举
 - 4、Web架构资产-平台指纹识别
-

- 1、开源-CMS指纹识别源码获取方式
 - 2、闭源-习惯&配置&特性等获取方式
 - 3、闭源-托管资产平台资源搜索监控
-

- 1、JS前端架构-识别&分析
- 2、JS前端架构-开发框架分析
- 3、JS前端架构-打包器分析
- 4、JS前端架构-提取&FUZZ

解决:

- 1、如何从表现中的JS提取价值信息
 - 2、如何从地址中FUZZ提取未知的JS文件
 - 3、如何从JS开放框架WebPack进行测试
-

- 1、端口扫描-应用&协议
- 2、WAF识别-分类&识别
- 3、蜜罐识别-分类&识别

解决:

- 1、Web服务器&应用服务器差异性
 - 2、WAF防火墙&安全防护&识别技术
 - 3、蜜罐平台&安全防护&识别技术
-

- 1、CDN 服务-解释差异识别
- 2、CDN 绕过-配置差异导致
- 3、CDN 绕过-主动连接获取
- 4、CDN 绕过-全网扫描获取

解决:

- 1、CDN 服务对安全影响
 - 2、CDN 服务绕过识别手法
-

- 1、CMS指纹识别-不出网程序识别
- 2、开发框架识别-PHP&Python&Java
- 3、开发组件识别-Java常见安全漏洞组件

解决:

- 1、CMS识别到后期漏洞利用和代码审计

2、开发框架识别到后期漏洞利用和代码审计

3、开发组件识别到后期漏洞利用和代码审计

- 1、Web&备案信息&单位名称中发现APP
- 2、APP资产静态提取&动态抓包&动态调试

解决:

1、如何获取到目标APP信息

2、如何从APP信息中提取资产

- 1、Web&备案信息&单位名称中发现小程序
- 2、小程序资产静态提取&动态抓包&动态调试

解决:

1、如何获取到目标小程序信息

2、如何从小程序中提取资产信息

- 0、工具项目-红蓝队&自动化部署
- 1、工具项目-自动化侦查收集提取
- 2、工具项目-综合&网络空间&信息

2.详细点



- 1 CMS
- 2 Discuz、WordPress、Ecshop、蝉知等



- 1 前端技术
- 2 HTML5、jquery、bootstrap、vue等



- 1 开发语言
- 2 PHP、JAVA、Ruby、Python、C#、JS等



- 1 web服务器
- 2 Apache、Nginx、IIS、lighttpd、Apache等



- 1 应用服务器:
- 2 Tomcat、Jboss、Weblogic、Websphere等



- 1 数据库类型:
- 2 Mysql、SqlServer、Oracle、Redis、MongoDB等



- 1 操作系统信息
- 2 Linux、windows等



- 1 应用服务信息:
- 2 FTP、SSH、RDP、SMB、SMTP、LDAP、Rsync等



- 1 CDN信息
- 2 帝联、Cloudflare、网宿、七牛云、阿里云等



- 1 WAF信息
- 2 创宇盾、宝塔、ModSecurity、玄武盾、OpenRASP等。



- 1 蜜罐信息:
- 2 HFish、TeaPot、T-Pot、Glastopf等



- 1 其他组件信息
- 2 fastjson、shiro、log4j、OA办公等

3.演示案例



- 1 #各类红蓝队优秀工具项目集合:
- 2 <https://github.com/guchangan1/All-Defense-Tool>
- 3 本项目集成了全网优秀的开源攻防武器项目, 包含信息收集工具(自动化利用工具、资产发现工具、目录扫描工具、子域名收集工具、指纹识别工具、端口扫描工具、各种插件...), 漏洞利用工具(各大CMS利用工具、中间件利用工具等项目...), 内网渗透工具(隧道代理、密码提取...), 应急响应工具、甲方运维工具、等其他安全攻防资料整理, 供攻防双方使用。如果你有更好的建议, 欢迎提出请求。

3.1 自动化-武器库部署-F8x



- 1 项目地址: <https://github.com/fffffffff0x/f8x>
- 2 1、介绍:
- 3 一款红/蓝队环境自动化部署工具,支持多种场景,渗透,开发,代理环境,服务可选项等.
- 4 2、配置:
- 5 通过 CF Workers 下载 [推荐]
- 6 wget : `wget -O f8x https://f8x.io/`
- 7 curl : `curl -o f8x https://f8x.io/`
- 8 3、使用: 见项目文档

3.2 自动化-企查信息-ENScan



- 1 项目地址: https://github.com/wgpsec/ENScan_GO
- 2 1、介绍:
- 3 剑指HW/SRC, 解决在HW/SRC场景下遇到的各种针对国内企业信息收集难题
- 4 2、配置:
- 5 ENScanGo在第一次使用时需要使用-v命令生成配置文件信息后进行配置
- 6 3、使用: 见项目文档

3.3 自动化-网络空间-AsamF



- 1 项目地址: <https://github.com/Kento-Sec/AsamF>
- 2 1、介绍:
- 3 AsamF集成了Fofa、Hunter、Quake、Zoomeye、Shodan、爱企查、Chinaz、0.zone、subfinder。AsamF支持Fofa、Hunter、Quake、Zoomeye、Shodan、Chinaz、0.zone配置多个key。
- 4 2、配置:
- 5 AsamF会在~/.config/asamf/目录下生成config.json文件。
- 6 如果你有, 建议键值按照阿拉伯数字依次录入,方便以阿拉伯数字来切换key。自动结果保存在~/asamf/目录下。
- 7 3、使用: 见项目文档

3.4 自动化-综合架构-ARL&Nemo



- 1 -ARL灯塔
- 2 项目地址: <https://github.com/TophantTechnology/ARL>
- 3 1、介绍:
- 4 旨在快速侦察与目标关联的互联网资产,构建基础资产信息库。协助甲方安全团队或者渗透测试人员有效侦察和检索资产,发现存在的薄弱点和攻击面。
- 5 2、配置: (docker搭建)
- 6 `git clone https://github.com/TophantTechnology/ARL`
- 7 `cd ARL/docker/`
- 8 `docker volume create arl_db`
- 9 `docker-compose pull`
- 10 `docker-compose up -d`

```
11 3、使用：见直播操作
12
13 -Nemo_Go
14 项目地址： https://github.com/hanc001/nemo\_go
15 1、介绍：
16 Nemo是用来进行自动化信息收集的一个简单平台，通过集成常用的信息收集工具和技术，实现对内网及互联网资产信息的自动收集，提高隐患排查和渗透测试的工作效率，用Golang完全重构了原Python版本。
17 2、配置：（docker搭建）
18 https://github.com/hanc001/nemo\_go/blob/main/docs/docker.md
19 下载release的nemo_linux_amd64.tar后执行：
20 mkdir nemo;tar xvf nemo_linux_amd64.tar -C nemo;cd nemo
21 docker-compose up -d
22 3、使用：见直播操作
23 4、Bug：网络空间（配置后要重启）
24 https://github.com/hanc001/nemo\_go/issues/72
```